

- (d) Reporting phase
32. Imagine you are explaining the concept of "realistic environment" for a lab to a new ethical hacker. Which of the following analogies would best illustrate the point?
- A flight simulator for pilots before they fly a real plane.
 - A sandbox for children to play in.
 - A training dummy for a boxer to practice on.
 - Testing a prototype system before developing.
33. Based on the steps and documents outlined, what is the correct sequence of events when establishing a penetration test engagement?
- Statement of Work (SOW) -> Master Service Agreement (MSA) -> Rules of Engagement (ROE).
 - Rules of Engagement (ROE) -> Master Service Agreement (MSA) -> Statement of Work (SOW).
 - Master Service Agreement (MSA) -> Statement of Work (SOW) -> Rules of Engagement (ROE).
 - Rules of Engagement (ROE) -> Statement of Work (SOW) -> Master Service Agreement (MSA).
34. Imagine you are a penetration tester writing a Statement of Work (SOW) for a client. What is a key piece of information you would need to include to ensure the project does not suffer from scope creep?
- A clear and detailed list of all devices and systems to be tested.
 - A list of all tools that will be used.
 - The names of the people on the testing team.
 - A summary of the final report.
35. An organization wants to develop a new "acceptable use" policy for its employees. What is one example of a security risk that this policy should address?
- Unauthorized use of company equipment to launch cyber attacks.
 - The lack of an external security audit that might cause inside attacks.
 - The cost of penetration testing.
 - The company's risk acceptance tolerance and risk mitigation.

Part II. Write TRUE if the statement is factually correct; otherwise, write FALSE if the statement is incorrect.

- TRUE 1. Social engineering attacks primarily target technological vulnerabilities in a network, not human behavior.
- TRUE 2. Pharming is a type of attack where a threat actor redirects a user from a legitimate website to a malicious one.
- TRUE 3. The Social-Engineer Toolkit (SET) is a tool used to launch numerous social engineering attacks.
- TRUE 4. Dumpster diving is a physical attack where a person scavenges for information in garbage containers.
- FALSE 5. Vishing is a social engineering attack that uses text messages to trick users. True
- TRUE 6. A watering hole attack is similar to a DDoS attack because it floods a website with traffic.
- TRUE 7. Tailgating and piggybacking are essentially the same, with the main difference being the consent of the authorized person.
- TRUE 8. The Browser Exploitation Framework (BeEF) is a tool that is primarily used to exploit vulnerabilities in a web browser by leveraging weaknesses like cross-site scripting (XSS).
- TRUE 9. An attacker who uses the "scarcity and urgency" method of influence might create a sense of panic in a victim by telling them their account will be deactivated if they do not act immediately.
- TRUE 10. A "USB drop key" attack is effective because victims are motivated by a sense of urgency to find out what is on the USB drive.
- TRUE 11. An attacker who poses as an IT support technician to gain access to a computer is using impersonation.

17. Explain the difference between an unknown-environment test and a known-environment test based on the information provided to the tester.
- a. Unknown-environment tests provide the tester with full network diagrams, while known-environment tests do not.
 - b. Unknown-environment tests are only performed on external networks, while known-environment tests are only on internal networks.
 - ☒ c. An unknown-environment test gives the tester no prior knowledge of the target, while a known-environment test gives them extensive knowledge, such as network diagrams and source code.
 - d. Unknown-environment tests are more expensive and time-consuming.
18. In the context of passive reconnaissance, why might an attacker be interested in a company's job listings?
- ☒ a. To find out about key contacts and their job responsibilities.
 - b. To use the job listings as a way to perform a denial-of-service attack.
 - c. To apply for a job at the company.
 - d. To identify what technologies the company uses in its environment.
19. A penetration tester is hired to test a company's web server and database. The tester is given a set of user credentials but no network diagrams or source code. What type of penetration testing will you use?
- a. Unknown-environment test (black-box)
 - b. Known-environment test (white-box)
 - c. Physical penetration test
 - ☒ d. Partially known environment test
20. A security researcher discovers a vulnerability in a new software application and publicly discloses it without first working with the vendor. What is this researcher considered?
- a. An ethical hacker
 - b. An insider threat
 - c. A white-box tester
 - ☒ d. A nonethical hacker
21. You are setting up a lab to practice testing web applications for vulnerabilities like SQL injection. Which methodology or guide would be most relevant for you to use as a reference?
- ☒ a. OWASP Web Security Testing Guide (WSTG)
 - b. MITRE ATT&CK
 - c. NIST SP 800-115
 - d. PTES
22. An attacker gains access to a corporate network by sending a malicious email to an employee, who then clicks on a link that allows the attacker access. What type of attack is this, and what kind of test would evaluate a company's defenses against it?
- ☒ a. Social engineering attack
 - b. Ransomware attack
 - c. SQL injection
 - d. Insider threat
23. An organization wants to perform a penetration test to evaluate the effectiveness of its security monitoring team. Which type of testing would be most suitable for this purpose?
- a. A known-environment test, because the testers can go straight to the critical systems.
 - ☒ b. A double-blind test, because the security team would be unaware of the test, mimicking a real attack.
 - c. A physical penetration test, to test the security guards.
 - d. A known-environment test, because the security team must be aware of the test.
24. A penetration tester identifies a vulnerability on a company's web server. After exploiting it, the tester wants to escalate their privileges to gain full administrative control of the system. In which phase of the PTES methodology would this action occur?
- a. The Reconnaissance Phase.